Related work & useful tools and technologies

1. **NVIDIA Garak (LLM Vulnerability Scanner)**

Garak e un scanner de vulnerabilități care seamănă cu Nmap sau Metasploit, dar este conceput pentru LLM-uri. Rolul său este să forțeze un LLM să eșueze pentru a putea testa limitele de Securitate (hallucinații, scurgeri de date, etc)

- **Date**: baze de date care conțin tehnici de read-teaming, prompt injection, data leakage și jailbreaks, structurate pe categoriile OWASP Top 10 LLM.
- **Algoritmi**: agenți AI și generatoare care construiesc și trimit prompturi malițioase pentru a evalua punctele slabe ale modelului testat.
- **Performanțe**: rularea automata a sute de teste și descoperirea unor vulnerabilități pe care testele simple de obicei le ratează
- **Librării/Tehnologii & Git:** Python; open-source GitHub (https://github.com/NVIDIA/garak)

Garak oferă seturi de date care ne vor ajuta la antrenare și tuning atunci când vom înlocui predicția hardcodată din AI-ul din proiectul nostru. De asemenea, ne-am inspirat de aici pentru ideea de a renunța la o interfață grafică, fiind probabil mai util ca proiectul nostrum să fie rulat din linia de comandă.

2. **LLM Guard (Protect AI)**

LLM Guard este un toolkit creat pentru apărarea aplicațiilor, fiind ca un firewall între utilizator și LLM.

- **Date**: seturi de date care conțin Personal Identifiable Information, tipare de toxicitate și semnături de prompt-injection, folosite pentru a sanitiza inputul și outputul
- **Algoritmi**: Modele de clasificare care analizează și filtrează datele în timp real
- **Performanțe**: Reducerea riscului de scurgere de informații sensibile + blocarea prompt-injectionurilor, având latența de câteva milisecunde.
- **Librării/Tehnologii & Git:** Python; open-source GitHub (https://github.com/protectai/llm-guard)

Mecanismele de filtrare din LLM Guard ne vor ajuta atunci când AI-ul va oferi sugestiile de remediere pentru vulnerabilitățile identificate.

3. **NeMo Guardrails (NVIDIA)**

NeMo Guardrails este un instrument care le permite dezvoltatorilor să impună reguli ("guardrails") LLM-urilor, asigurându-se că nu deviază de la subiect și nu execută acțiuni nesigure.

- **Date**: dialoguri și seturi de reguli concepute pentru a menține agenții doar pe topicuri autorizate (deci fără politică, medical advice, etc)
- **Algoritmi**: Colang (specific pentru modelarea dialogului) + Execution & Output guardrails, care evaluează deciziile LLM-ului.
- **Performanțe**: Prevenirea execuțiilor neautorizate de cod sau de instrumente + blocarea de system prompt leakages
- **Librării/Tehnologii & Git:** Python, cu integrare nativă pentru LangChain; open-source GitHub (https://github.com/NVIDIA-NeMo/Guardrails)

Modul în care NeMo interceptează și controlează fluxul datelor ne ajută să înțelegem cum arată un cod sigur pentru agenți. Acest lucru ne va oferi un model de referință pe care scannerul nostru să îl poată recunoaște.

4. **Promptfoo (LLM Evaluation Framework)**

Promptfoo este un CLI și librărie pentru evaluarea calității și securității aplicațiilor bazate pe LLM-uri, testând prin read-teamming modelele înainte de lansarea în producție.

- **Date**: Seturi de teste personalizate și matrici de evaluare. Acestea descriu comportamentul așteptat de la model în diferite scenarii de atac sau eroare
- **Algoritmi**: se bazează pe conceptul de LLM-as-a-judge, unde un model evaluează și notează răspunsurile unui model mai slab.
- **Performanțe**: Automatizarea testării, rulând mai multe prompturi în același timp și generând rapid matrici cantitative de tip pass/fail
- **Librării/Tehnologii & Git:** Node.js / TypeScript și funcționează din linia de comandă. open-source GitHub (https://github.com/promptfoo/promptfoo)

În faza finală de testare a AI-ului nostru ne putem folosi de metoda llm-as-judge, automatizând comparația dintre AI-ul intenționat vulneravil și versiunea corectă.

5. Giskard (Open-Source AI Testing)

Giskard este un framework dedicat testării și evaluării modelelor AI, axat în special pe detectarea vulnerabilităților în sisteme complexe precum RAG (Retrieval-Augmented Generation).

- **Date:** baze de cunoștințe specifice sistemelor RAG și liste documentate cu scenarii de divulgare (scurgere) a datelor.
- **Algoritmi:** agenți autonomi de red-teaming capabili să își adapteze atacurile în mod dinamic pe parcursul unei conversații multi-turn

- **Performante:** identificarea breșelor complexe din conductele RAG și a vulnerabilităților pe care scanerele statice obșnuite nu le pot detecta.
- **Librării/Tehnologii & Git:** Python, LangChain; open-source GitHub (https://github.com/Giskard-AI/giskard)

Fiind construit nativ pentru ecosistemul Python și LangChain, codul lor sursă reprezintă o sursp excelentă de inspirație pentru metodele noastre de parsare a fișierelor și de extragere a contextului în vederea unei analize de securitate profunde.

6. CyberSecEval 2 (Meta / PurpleLlama)

CyberSecEval 2 este o suită de evaluare dezvoltată de Meta, concepută pentru a măsura și îmbunătăți rezistența modelelor LLM la amenințările de securitate cibernetică, în special în generarea de cod.

- **Date:** benchmark-uri complexe care includ provocări de cod sursă vulnerabil, teste pentru autocomplete nesigur și payload-uri specifice injecțiilor de prompturi.
- **Algoritmi:** un model LLM separat cu rol de "judge" pentru clasificarea gradului de malițiozitate, functionând în paralel cu detectoare statistice pentru cod nesigur (Insecure Code Detectors).
- **Performanțe:** generarea unor metrici precise de complianță și introducerea evaluării ratei de refuz fals (situațiile în care modelul blochează instrucțiuni inofensive).
- **Librării/Tehnologii & Git:** Python; open-source GitHub sub suita PurpleLlama (https://github.com//meta-llama/PurpleLlama)

Proiectul include benchmark-uri validate cu cod sursă vulnerabil pe care le putem descărca direct. Acestea vor reprezenta "datele de intrare" perfecte pentru testarea finală, ajutându-ne să verificăm dacă AI-ul nostru reușește să senaleze corect fișierul, linia de cod afectată si categoria OWASP corespunzătoare.